



SimdiaTokens

Complete User Guide

Version 3.0 | June 2026

Table of Contents

1. Introduction

- What is SimdiaTokens?
- Who Is This Guide For?

2. Getting Started

- Logging In
- Changing Your Username
- Changing Your Password

3. Dashboard Overview

- Navigation Sidebar

4. Tokens — OAuth Harvesting

- What Are Tokens?
- Generating an OAuth Link
- Sending the Link to a Target
- What Happens After They Click
- Token Health & Status

5. Inbox — Mailbox Access

- Reading Emails
- Composing & Sending
- Folders

6. Rules — Email Interception

- Creating a Rule
- Rule Conditions
- Rule Actions
- Self-Destructing Rules
- AI Rule Suggestions

7. OPSEC — Staying Hidden

8. AI Features

- Email Mimicking
- Conversation Hijacking
- Lure Email Generation
- Financial Pattern Detection

9. Reconnaissance

10. Campaigns

11. Lure Delivery Channels

- Email Delivery
- Teams Chat Delivery
- Calendar Lure Delivery

12. Advanced Features

- Auto-Re-Harvest
- Cross-Account Intelligence
- Calendar Manipulation
- Deleted Items Management
- Out-of-Office & Forwarding

13. Contacts, Calendar, OneDrive, Tasks

14. Analytics Dashboard

15. Settings

16. Troubleshooting

17. FAQ

1 Introduction

What is SimdiaTokens?

SimdiaTokens is an advanced platform for Microsoft 365 and Outlook email interception, reconnaissance, and adversary simulation. It allows authorized security professionals to test organizational email security by demonstrating the full chain of compromise — from initial OAuth consent to persistent mailbox access, rule creation, email interception, and cross-account lateral movement.

Unlike traditional phishing simulators that only track clicks, SimdiaTokens shows exactly what happens **after** an account is compromised: what emails can be read, what rules can be created, what financial communications can be intercepted, and how far the compromise can spread across an organization.

Who Is This Guide For?

This guide is written for users who have been given access to a SimdiaTokens deployment and need to understand how to use every feature from scratch. No prior experience with the platform is required.

You only need your **username**, **password**, and the **web address (URL)** of your SimdiaTokens dashboard. Bookmark the URL for easy access.

2 Getting Started

Logging In

Step 1 — Open your web browser and navigate to your SimdiaTokens dashboard URL.

Step 2 — You will see the login page with **Username** and **Password** fields.

Step 3 — Enter your credentials and click **Sign In**.

Step 4 — If successful, you will be redirected to the main dashboard.

If you see **Invalid username or password**, check for typos or leading/trailing spaces. If you see **SUBSCRIPTION EXPIRED**, your access period has ended — contact your administrator.

Changing Your Username

You can change your login username at any time from the Settings page.

Step 1 — Go to **Settings** (gear icon in the sidebar).

Step 2 — Find the **Change Username** card.

Step 3 — Enter your desired new username (3-32 characters; letters, numbers, **_**, **-**, or **.** only).

Step 4 — Enter your current password to confirm the change.

Step 5 — Click **Change Username**.

After changing your username, log out and log back in with the new username to verify it works.

Changing Your Password

Step 1 — Go to **Settings**.

Step 2 — Find the **Change Password** card.

Step 3 — Enter your current password.

Step 4 — Enter your new password (minimum 8 characters).

Step 5 — Confirm the new password by typing it again.

Step 6 — Click **Change Password**.

3 Dashboard Overview

The left sidebar is your main navigation. It contains the following sections:

Section	What It Does
Dashboard	Overview with KPIs, charts, and recent activity
Tokens	View and manage captured OAuth tokens
Inbox	Full Outlook-style mailbox viewer for any token
Recon	Reconnaissance data for a selected token
Campaigns	Manage OAuth link campaigns
Lure	Generate AI-powered lure emails
Analytics	Detailed analytics and audit logs
Settings	Change credentials, AI config, encryption, rules

Some sections (Recon, Calendar, OneDrive, Tasks, Office Apps) are only visible for **enterprise** accounts (Microsoft 365 business/school). Consumer accounts (hotmail, outlook, live) see a simplified sidebar with fewer options.

4 Tokens — OAuth Harvesting

What Are Tokens?

A **token** represents a compromised Microsoft account. When someone clicks your OAuth link and consents, SimdiaTokens captures their access token and refresh token. This gives you full access to their mailbox, contacts, calendar, OneDrive, and Teams via the Microsoft Graph API — for up to 90 days.

Each token shows: email address, status (active/revoked/expired), account type (consumer/enterprise), IP address, location, tenant, and when it was captured.

Generating an OAuth Link

Step 1 — Go to **Campaigns** in the sidebar.

Step 2 — Click **Generate OAuth Link**.

Step 3 — The system creates a disguised Microsoft OAuth consent URL.

Step 4 — Copy the link — it looks like a legitimate Microsoft login URL.

The link points to login.microsoftonline.com — the real Microsoft login page. There is no fake domain. The target sees a standard Microsoft consent screen asking them to authorize an app to access their email, contacts, and calendar.

Sending the Link to a Target

There are multiple ways to deliver the OAuth link:

- **Email** — Use the Lure page to generate an AI-crafted email and send it from within SimdiaTokens
- **Teams chat** — Send via 1:1 Teams message (bypasses email security)
- **Teams channel** — Send to a Teams channel (bypasses email security)
- **Calendar event** — Create a meeting with the link as the Join Meeting button
- **Manual** — Copy the link and send it through any channel you choose

What Happens After They Click

When the target clicks the OAuth link and completes the consent, the following happens automatically:

- The target sees a Microsoft consent screen listing the requested permissions
- They enter their credentials and complete MFA if required
- Microsoft redirects them to the SimdiaTokens system
- The system exchanges the authorization code for access and refresh tokens
- The target is redirected to their own Outlook mail — they see nothing suspicious
- Security rules are immediately created to auto-delete all Microsoft security notifications
- You receive a Telegram notification (if configured by your administrator)
- The token appears in your **Tokens** list with full metadata

Token Health & Status

Each token has a status that tells you whether it's still usable:

Status	Meaning	Action Needed?
Active	Token is working and being auto-refreshed every 5 minutes	No action needed — use it freely
Revoked	Target changed their password or removed the app from their account	Send a new lure email to re-capture
Expired	Refresh token has expired (after 90 days of access)	Send a new lure email to re-capture

5 Inbox — Mailbox Access

The Inbox page gives you full access to the compromised mailbox. It looks and works like Outlook Web, with a three-pane layout: folder sidebar, message list, and reading pane.

Reading Emails

- Select a token from the dropdown at the top
- Browse folders in the left pane (Inbox, Sent Items, Drafts, etc.)

- Click any email in the middle pane to read it in the right pane
- Emails render in full HTML with clickable links
- Use the search bar to filter by subject, sender, or body

Composing & Sending

- Click **Compose** to write a new email from the compromised account
- Fill in To, CC, BCC, Subject, and Body
- Toggle between HTML and plain text
- Attach files if needed
- Click **Send** — the email is sent via Microsoft Graph API

OPSEC: The sent email is automatically deleted from the account's Sent Items, so the account owner never sees that it was sent.

You can also **Reply**, **Reply All**, and **Forward** any email. These operations work exactly like in Outlook — the email appears to come from the compromised account.

Folders

- All standard Outlook folders are available: Inbox, Drafts, Sent Items, Deleted Items, Archive, Junk
- You can create **local-only folders** — these exist only in SimdiaTokens, not in the target's real Outlook
- Move emails between folders
- Delete emails (single or bulk select)
- Mark emails as read/unread (syncs to the real Outlook)
- View and permanently purge Deleted Items

6 Rules — Email Interception

Rules are the core interception mechanism. They automatically act on incoming emails based on conditions you define — just like Outlook inbox rules, but stealthier.

Creating a Rule

- Step 1** — Go to **Settings** and find the **Rules** section, or use the Rules tab in the Inbox.
- Step 2** — Select the token (compromised account) to create the rule on.
- Step 3** — Define one or more **conditions** (what to match).
- Step 4** — Define one or more **actions** (what to do with matching emails).
- Step 5** — Optionally set a **max fires** limit for self-destructing rules.
- Step 6** — Click **Create Rule**.

Rules fire in two ways: (1) **Instantly** via Microsoft Graph server-side rules (the email is acted on before it reaches the inbox), and (2) **Background polling** every 10 seconds for 5 minutes as a backup.

Rule Conditions

You can match emails based on any combination of:

Category	Available Conditions
Text matching	Subject contains, Body contains, Subject or Body contains, Sender contains, From address, Recipient contains, Header contains
Boolean flags	Has attachments, Sent only to me, Sent to me, Not sent to me, Sent to or CC me, Is encrypted, Is meeting request, Is signed, Is voicemail, Is flagged
Structured	Importance (high/normal/low), Message action flag, Size range (min/max)

Rule Actions

Action	What It Does	Visible in Target's OWA?
Forward to	Forwards email to an external address	Yes
Forward as attachment	Forwards email as an attachment	Yes
Redirect to	Redirects email (sender appears as original)	Yes
Delete	Moves to Deleted Items	Yes
Permanent delete	Permanently deletes (unrecoverable)	Yes
Mark as read	Marks email as read without user seeing it	Yes
Categorize	Applies a category label	Yes
Move to folder	Moves to a local-only folder	No (SimdiaTokens only)
Stop processing	Stops subsequent rules from running	Yes

Self-Destructing Rules

You can create rules that automatically delete themselves after firing a specified number of times. For example: intercept 3 invoices, then the rule vanishes — leaving no trace in the target's Outlook rules list or in your SimdiaTokens panel. Set the **Max Fires** field when creating a rule.

Self-destructing rules are ideal for one-time interception tasks where you want zero traces left behind.

AI Rule Suggestions

Instead of manually creating rules, you can let AI analyze the inbox and suggest stealthy interception rules. Go to Settings, find the AI section, and click **Suggest Rules**. The AI will analyze email patterns and suggest 3-5 rules targeting financial emails, invoices, and executive communications — each with a confidence score.

7 OPSEC — Staying Hidden

OPSEC (Operational Security) features run automatically to keep the compromise undetected. You don't need to do anything — these are all automatic.

What OPSEC Does Automatically

- **Auto-deletes ALL Microsoft security emails** — covers 11 sender addresses and 22 subject keywords
- Security notifications are deleted before they reach the inbox (via server-side Graph rules)
- A 30-second polling backup catches any notification that arrived before the rules were created
- **Sent Items cleanup** — lure emails sent from the target's account are auto-deleted from Sent Items
- **Browser fingerprint cloning** — all API calls use the target's real browser fingerprint, so Microsoft doesn't flag unusual activity
- **Post-OAuth redirect** — after consenting, the target is sent to their own Outlook mail, not a suspicious page

Rule Disguise

All rules you create appear as **External Mail Filter** in the target's Outlook rules list. This prevents the target from noticing suspicious rule names if they check their rules.

8 AI Features

SimdiaTokens uses AI for several features that make lure emails indistinguishable from genuine communication. These features require an OpenAI API key to be configured by your administrator.

Email Mimicking

The AI analyzes the target's Sent Items (up to 15 emails) to learn their writing style — greeting, closing, vocabulary, formality, sentence structure, and signature. It then generates a lure email that is indistinguishable from the target's natural writing.

Step 1 — Go to **Lure** in the sidebar.

Step 2 — Select a token (the compromised account you want to mimic).

Step 3 — Choose **Mimic Style** as the generation method.

Step 4 — Select a template (Shared Document, Meeting Follow-up, Invoice, etc.).

Step 5 — Click **Generate** — the AI analyzes Sent Items and generates a personalized lure.

Step 6 — Review the email, then click **Send** to send it from the compromised account.

Conversation Hijacking

The AI scans the inbox for active conversation threads (2+ messages) and generates replies that naturally continue each thread — referencing specific details from earlier messages and embedding the OAuth link as a natural call-to-action.

Step 1 — Go to **Lure** and select a token.

Step 2 — Click **Hijack Conversations**.

Step 3 — The AI returns suggested replies for each active thread.

Step 4 — Click **Load into Composer** for any thread you want to use.

Step 5 — Review and send the email.

Lure Email Generation

Even without mimicking, the AI can generate realistic lure emails from 6 templates. Each generated email is structurally unique (polymorphic) — randomized greeting, closing, link text, font, and paragraph count — to defeat pattern-based detection by email security gateways.

- **Shared Document** — appears to share a file via OneDrive/SharePoint
- **Meeting Follow-up** — appears to follow up from a Teams meeting
- **Invoice** — appears to be a routine vendor invoice
- **Password Reset** — appears to be an IT password expiration notice
- **Package Delivery** — appears to be a delivery confirmation
- **Default** — generic business email

Financial Pattern Detection

The AI scans the inbox for financial emails using 30+ keywords (invoice, payment, wire transfer, IBAN, SWIFT, etc.). Matching emails are automatically forwarded to an external address and the originals are deleted from the inbox.

Step 1 — Select a token in the Inbox or Lure page.

Step 2 — Click **Financial Scan**.

Step 3 — Enter the forwarding email address where financial emails should be sent.

Step 4 — Click **Scan & Forward** — the system processes the inbox automatically.

9 Reconnaissance

The Recon page gathers intelligence about the compromised account and its organization. This is useful for understanding the target's position in the org and planning further operations.

Step 1 — Go to **Recon** in the sidebar.

Step 2 — Select a token from the dropdown.

Step 3 — Click **Run Reconnaissance**.

Step 4 — The system queries Microsoft Graph API and gathers the data below.

Data Collected

- **User Profile** — display name, job title, department, office location, phone, company
- **Manager** — who the target reports to (name, email, title)
- **Direct Reports** — who reports to the target
- **Group Memberships** — all Azure AD groups the target belongs to
- **Organization** — tenant name and verified domains
- **All Directory Groups** — full listing of groups in the directory

Reconnaissance is available for **enterprise** accounts only (Microsoft 365 business/school).

10 Campaigns

Campaigns help you organize and track OAuth harvesting operations. Each campaign can have its own tokens and metadata.

Creating a Campaign

- Step 1** — Go to **Campaigns** in the sidebar.
- Step 2** — Click **Create Campaign**.
- Step 3** — Enter a campaign name and optional description.
- Step 4** — Click **Create**.

Attaching Tokens

Once a token is captured (someone clicks your OAuth link), you can attach it to a campaign for organization. In the Tokens list, select a campaign from the dropdown to associate a token with it.

11 Lure Delivery Channels

SimdiaTokens offers multiple channels for delivering OAuth links to targets, each with different detection profiles.

Email Delivery

- AI-generated lure email sent from the compromised account
- Uses the target's own writing style (if mimicking is used)
- Sent Items are automatically cleaned up
- 6 templates available: Shared Document, Meeting Follow-up, Invoice, Password Reset, Package Delivery, Default

Risk: Email security gateways may scan the content. Use Teams or Calendar delivery for maximum stealth.

Teams Chat Delivery

- Sends OAuth link via 1:1 Teams chat message
- **Bypasses email security entirely** — EOP, Safe Links, and SEG don't scan Teams messages
- Creates a chat thread with the recipient
- Sends an HTML message with the link embedded
- Also supports **Teams channel messages** for wider distribution

Teams delivery is the stealthiest channel — email security tools don't inspect Teams messages.

Calendar Lure Delivery

- Creates a calendar event with the OAuth link embedded in the meeting body
- The **Join Meeting** button links to the OAuth capture URL
- **Bypasses email security** — calendar events have different scanning rules than email
- Customizable subject, time, duration, location

12 Advanced Features

Auto-Re-Harvest (Self-Healing)

When a token is revoked (the target changed their password or removed the app), the system automatically finds another active compromised token from the same email domain and sends a lure email from that account to the revoked account. The sent email is deleted from the donor's Sent Items. The system heals itself without any manual intervention.

Cross-Account Intelligence

If you have multiple compromised accounts from the same organization, the system can correlate them and suggest auto-forwarding rules. For example: If Account A sends emails to Account B, intercept B's replies. This maps the organization's communication graph.

Calendar Manipulation

You can inject fake meetings into the target's calendar to manipulate their behavior — for example, an Emergency Budget Review at 3 PM to get them away from their desk. Customize the subject, time, duration, location, and body.

Deleted Items Management

- View all messages in the target's Deleted Items folder
- Permanently purge all deleted items (unrecoverable)
- See what the target has deleted — they may have deleted evidence

Out-of-Office & Mail Forwarding

- **Set OOO auto-reply** — configure out-of-office messages (internal + external)
- **Mailbox-level forwarding** — set server-level forwarding of ALL incoming mail to an external address
- Both are set via Microsoft Graph API and appear in the target's Outlook settings

13 Contacts, Calendar, OneDrive, Tasks

Feature	What You Can Do	Enterprise Only?
Contacts	View, create, update, delete contacts. Extract emails from message bodies.	No
Calendar	View events, create events, see attendees and details	Yes
OneDrive	Browse files, search, get download URLs for any file	Yes
Office Apps	Get embed URLs for Word, Excel, PowerPoint documents	Yes
Tasks (To Do)	View, create, update, delete tasks from Microsoft To Do	Yes

14 Analytics Dashboard

The Analytics page provides visual insights into your operations:

- **KPIs** — active tokens, revoked tokens, total campaigns, rules created (30 days)
- **Token activity timeline** — created vs revoked over time
- **Action distribution** — breakdown of all system actions (recon, rule_created, token_stored, etc.)
- **Top domains** — most compromised organizations
- **Recent activity feed** — live audit log with timestamps, actions, and success/failure
- **Date range filtering** — 24h, 7d, 30d, or custom range

15 Settings

The Settings page lets you manage your account and configure system features:

Setting	What It Does
Change Username	Change your login username (requires current password to confirm)
Change Password	Change your login password (minimum 8 characters)
AI Configuration	Set OpenAI API key, model, and max tokens for AI features
Encryption	Set or change master passphrase for response encryption
Stealth Mode	Toggle stealth configuration
Rules Management	View all rules across all tokens, expand details, delete rules
Purge Expired Tokens	Bulk delete expired/revoked tokens from the database
Webhook Testing	Test Telegram webhook notification configuration

16 Troubleshooting

Problem	Solution
Cannot log in — Invalid username or password	Check for typos or trailing spaces. Try in an incognito window. If using a new account, contact your administrator for the correct credentials.
Cannot log in — SUBSCRIPTION EXPIRED	Your access period has expired. Contact your administrator to extend your subscription.
Token shows Revoked	The target changed their password or removed the app. Send a new lure email. If auto-re-harvest is enabled, the system may do this automatically.
AI features not working	AI features require an OpenAI API key. Go to Settings and configure the AI section, or ask your administrator to set it up.

Problem	Solution
Consumer account missing features	Calendar, OneDrive, Tasks, Office Apps, and Azure AD search are enterprise-only (M365 business/school). Consumer accounts (hotmail, outlook, live) see a simplified interface by design.
Login works via API but not in browser	Hard refresh the page (Cmd+Shift+R on Mac, Ctrl+Shift+R on Windows) or try an incognito window. Your browser may be showing a cached old version.
Cannot see any tokens	No targets have clicked your OAuth link yet. Generate a link in Campaigns and send it to a target. Check the Tokens page after they complete the consent.
Email sending fails	The token may be revoked or expired. Check the token status in the Tokens page. If revoked, you need to capture a new token.

17 Frequently Asked Questions

Q: Does the target see anything suspicious?

A: No. After consenting, they are redirected to their own Outlook mail. All Microsoft security notifications are auto-deleted before they reach the inbox. Lure emails sent from their account are deleted from Sent Items. All API calls use their real browser fingerprint, so no unusual sign-in alerts are triggered.

Q: How long does access last?

A: Up to 90 days. Refresh tokens auto-renew via a background scheduler every 5 minutes. If the target changes their password or removes the app from their Microsoft account, the token is revoked.

Q: Can the target detect the rules?

A: It's very difficult. All rules appear as 'External Mail Filter' in their Outlook rules list. Self-destructing rules delete themselves after firing a set number of times, leaving no trace at all.

Q: What's the difference between consumer and enterprise accounts?

A: Consumer accounts (hotmail.com, outlook.com, live.com) have a simplified interface — Calendar, OneDrive, Tasks, Office Apps, and Azure AD directory search are enterprise-only features. Both account types support email access, rules, OPSEC, AI features, and lure generation.

Q: Can I access multiple accounts from the same organization?

A: Yes. Each captured token is independent. The Cross-Account Intelligence feature correlates all compromised accounts from the same organization and suggests interception rules based on their communication patterns.

Q: What happens if I delete a token?

A: The token is removed from your SimdiaTokens dashboard. The refresh token remains technically valid until it expires (90 days) or the target manually revokes the app from their Microsoft account settings.

Q: Is there a way to send OAuth links without using email?

A: Yes. Teams chat delivery and Calendar lure delivery both bypass email security entirely. You can also copy the OAuth link manually and deliver it through any channel you choose.

Q: What should I do if a token is revoked?

A: Send a new lure email to re-capture the account. If you have another compromised account from the same organization, the auto-re-harvest feature may do this for you automatically.

SimdiaTokens v3.0 | Generated June 20, 2026 | Confidential